ICS441 LAB 2

Practical Reconnaissance & OSINT Investigation

Recommended Duration	3–4 hours	**Mode**	Individual / pairs
Environment	Own Computer/ local VM	**Evidence**	Screenshots + notes + export files
Core Principle	Passive first; active only with written authorization		

1. Learning Objectives

1. Perform passive reconnaissance using legally accessible public information sources.
2. Use modern internet-intelligence platforms such as Censys and Shodan to understand exposed infrastructure without scanning the target directly.
3. Use DNS, certificate-transparency and domain-intelligence sources to map an authorised external attack surface.
4. Use current practitioner tooling such as OWASP Amass and ProjectDiscovery Subfinder to automate passive asset discovery.
5. Use technology-fingerprinting and HTTP probing tools appropriately, distinguishing passive observation from active interaction.
6. Extract and interpret metadata from public or lecturer-supplied files using ExifTool or FOCA.
7. Correlate entities and relationships using Maltego and structured evidence tables.
8. Enrich IP and URL observations using GreyNoise, VirusTotal and urlscan.io.
9. Check credential-exposure information safely with Have I Been Pwned using only personal, demo, or lecturer-provided identities.
10. Document evidence, confidence, limitations, ethics, privacy, and legal boundaries in a professional OSINT report.

Mandatory Ethics, Authorization and Safety Rules

IMPORTANT: Discovery does not create permission to test. Passive sources may be used only in line with their terms of service. Active tools such as httpx, Katana, Naabu or Nuclei must be used only against an instructor-owned, locally hosted, or explicitly authorised target

- Do not scan, probe, crawl, fuzz, exploit, brute-force, or authenticate against public third-party systems without explicit permission.
- For active exercises, use a local OWASP Juice Shop/DVWA instance, a dedicated cyber range, or a domain/IP specifically supplied by the lecturer.
- Do not submit confidential documents, private URLs, tokens, or institutional data to public intelligence services.
- Use only your own email address, a lecturer-provided demo identity, or an approved test identity when checking breach exposure.
- Record which actions were passive and which actions interacted directly with the target.
- If the scope is unclear, stop and ask the lecturer before continuing.

Pre-Lab Preparation

- Any modern Windows, macOS or Linux system with Internet access.
- Web browser: Chrome, Edge or Firefox.

- Free accounts where required: Censys, Shodan, SecurityTrails (if available), Maltego CE, VirusTotal, urlscan.io, Have I Been Pwned.
- Optional CLI tools: OWASP Amass, Subfinder, httpx, Katana, ExifTool. Nuclei only for the optional authorised-local extension.
- Lecturer-supplied target scope sheet identifying which target(s) are passive-only and which lab target(s) may be actively queried.
- Local or cyber-range web target for active steps. A local OWASP Juice Shop deployment is recommended; do not treat the public OWASP project website itself as an authorised scanning target.

Lab Tasks

Task 0 – Scope & Interaction Classification (10 min)

Suggested sample target(s): Passive examples: example.com, example.org, owasp.org. Active lab examples: juice-shop.local, dvwa.local, webgoat.local, crapi.local.

- Create a two-column scope table: PASSIVE-ONLY sources and ACTIVE-AUTHORISED targets.
- Write the exact domain/IP/URL that the lecturer has approved.
- For each tool you intend to use, classify it as passive dataset lookup, local analysis, or direct target interaction.
- Deliverable: one-page scope and authorization note.

Task 1 – RDAP / WHOIS & Domain Registration Context (10 min)

Suggested sample target(s):example.com or example.org. Perform an RDAP or WHOIS lookup for the approved domain.

- Record registrar, registration dates, nameservers and any organisation-level details legitimately exposed.
- Compare the result with a second source if available.
- Question: Which registration details are reliable facts, and which may be privacy-protected or stale?

Task 2 – Censys + Shodan Exposure Comparison (20 min)

Suggested sample target(s):scanme.nmap.org. For this task, use only existing Censys/Shodan observations; do not trigger a fresh scan.

- Search the approved domain/IP in Censys and Shodan using their existing datasets.
- Record observed ports/services, certificates, hostnames, software hints and timestamps where available.
- Do not launch a fresh scan against a third-party target.
- Create a comparison table: Censys observation | Shodan observation | confidence | follow-up required.
- Question: Why can two internet-intelligence platforms show different results for the same asset?

Task 3 – DNS, SecurityTrails & Certificate-Transparency Discovery (20 min)

Suggested sample target(s):owasp.org or badssl.com for passive certificate/DNS observations

- Use SecurityTrails where available and certificate-transparency sources such as crt.sh to identify DNS/hostname relationships.
- Record discovered hostnames and note the source and observation date.
- Mark every discovered hostname as: in scope, out of scope, or requires scope confirmation.
- Question: Why does discovering a subdomain not automatically authorise interaction with it?

Task 4 – Modern Passive Subdomain Automation with Subfinder / Amass (20 min)

Suggested sample target(s):owasp.org in passive mode. Discovery does not authorise probing any returned subdomain.

- Use Subfinder in passive mode against the lecturer-approved domain, or use a lecturer-supplied dataset if Internet/API access is restricted.

- Use OWASP Amass in passive/OSINT mode for comparison.
- Deduplicate the resulting hostname list.
- Deliverable: a table showing hostname, source/tool, corroborating source and confidence.
- Question: Which names appeared in more than one independent source?

Task 5 – Technology Fingerprinting (15 min)

Suggested sample target(s): BuiltWith/Wappalyzer: owasp.org. httpx: juice-shop.local, dvwa.local or webgoat.local only.

- Use BuiltWith or Wappalyzer to identify visible technologies on the approved web target.
- If the lecturer has supplied an active lab target, use httpx only against that lab target to verify HTTP status, title and basic technology indicators.
- Do not assume that a detected technology means a specific CVE is exploitable.
- Deliverable: three technology observations with evidence and confidence level.

Task 6 – urlscan.io & VirusTotal Intelligence (15 min)

Suggested sample target(s):example.com, badssl.com. Prefer searching existing results.

- Search existing urlscan.io results for the approved domain or lecturer-supplied URL. Prefer historical/search results rather than submitting a new public scan.
- Use VirusTotal to review existing URL/domain/IP intelligence.
- If uploading a file, use only a benign lecturer-supplied sample with no confidential information.
- Question: What privacy risk can arise when analysts upload URLs or files to public analysis platforms?

Task 7 – Metadata Extraction with ExifTool / FOCA (20 min)

Suggested sample target(s): Use any sample file on your PC; do not crawl for documents unless explicitly authorised.

- Use a lecturer-supplied PDF, DOCX or image file, or a public document that is clearly within the approved research scope.
- Extract metadata locally with ExifTool. FOCA may be used as a Windows comparison tool.
- Record at least two metadata fields and explain whether each is operationally useful, outdated, or privacy-sensitive.
- Deliverable: screenshot plus a short evidence interpretation.

Task 8 – Maltego Correlation Graph (25 min)

Suggested sample target(s):example.com, owasp.org,

- Create a new Maltego graph and add the approved domain as the seed entity.
- Run only transforms permitted by the lecturer and the service terms.
- Correlate domain, DNS, certificate, IP and organisation-level relationships.
- Export the graph as PNG.
- Question: Which relationships are observed facts and which are inferred relationships requiring validation?

Task 9 – GreyNoise IP Context (10 min)

Suggested sample target(s): Resolve scanme.nmap.org and use its current public IP for lookup, GreyNoise lookup only; no probing.

- Select one lecturer-approved public IP already observed through passive sources.
- Query GreyNoise for context on internet scanning/noise and relevant tags if data is available.
- Record what GreyNoise can and cannot tell you about the asset.
- Question: How can internet-scanner intelligence reduce false assumptions during reconnaissance?

Task 10 – Have I Been Pwned (10 min)

Suggested sample target(s): No domain target. Use your own email address or a lecturer-provided demo identity only.

- Use only your own email, a lecturer-provided demo account, or another explicitly approved test identity.
- Review breach information and identify defensive actions such as password changes, MFA and credential monitoring.
- Do not test colleagues, students or third parties without consent/authority.
- Question: Why is breach intelligence useful for defensive awareness but sensitive from a privacy perspective?

Post-Lab Questions

- Which three tools provided the most actionable intelligence, and why?
- Compare Censys and Shodan. Which observations were corroborated and which differed?
- How did certificate-transparency and DNS intelligence expand the visible attack surface?
- What is the difference between passive discovery and active verification in this lab?
- Which findings had low confidence and what additional evidence would be required?
- How can an organisation reduce unnecessary external exposure identified through OSINT?
- What privacy or data-protection risks can arise when using public analysis services?
- Which modern tool would you recommend for continuous external attack-surface monitoring and why?
- What evidence would justify escalating from passive reconnaissance to an authorised active test?
- How did the 2026 toolchain change your understanding of professional reconnaissance compared with using WHOIS, FOCA and Recon-ng alone?

Assessment / Deliverables

- A short professional lab report containing a title page, scope statement, methods, findings, limitations and recommendations.
- Screenshots or exports showing key evidence from ALL the Tools used.
- A tool-classification matrix showing passive dataset, local analysis, and active interaction.
- Written answers to all Post-Lab Questions.
- One paragraph recommending how the authorised organisation could reduce unnecessary external exposure.
- An ethics statement confirming that no unauthorised scanning, probing or exploitation was performed.

Current Tool References (Official Sources)

- **ProjectDiscovery Quick Start / toolchain:** https://docs.projectdiscovery.io/quickstart
- **ProjectDiscovery Subfinder:** https://docs.projectdiscovery.io/opensource/subfinder/overview
- **ProjectDiscovery Katana:** https://docs.projectdiscovery.io/opensource/katana/overview
- **ProjectDiscovery Nuclei:** https://github.com/projectdiscovery/nuclei
- **OWASP Amass:** https://owasp.org/www-project-amass/
- **Censys Platform:** https://docs.censys.com/docs/platform-quickstart-guide
- **SecurityTrails API:** https://docs.securitytrails.com/docs/overview
- **urlscan.io Documentation:** https://urlscan.io/docs/
- **GreyNoise Platform:** https://www.greynoise.io/greynoise-product

Final Disclaimer

This lab is for authorised educational security assessment only. Students must not scan, crawl, probe, exploit, brute-force or otherwise interact with systems that are not explicitly included in the lecturer-

approved scope. Publicly visible information does not create permission to test a system. The objective is to develop responsible professional reconnaissance skills that can be defended using evidence, ethics and documented authorization.